Vulnexa PRO

ASSESSMENT TARGET
pachchigarjewellers.com

SCAN COMPLETION DATE
24/3/2026, 10:13:13 am

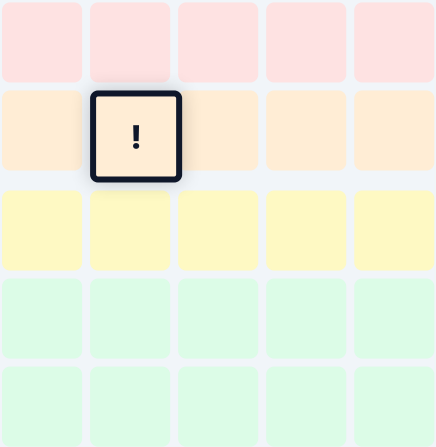
Executive Summary

Proprietary Security Exposure Assessment for pachchigarjewellers.com

75/100

POSTURE: HIGH

RISK POSTURE ANALYSIS



Risk Impact vs. Probability

Based on our automated analysis, the target application demonstrates a **HIGH** operational risk profile. This score integrates vulnerability counts, exploitability, and potential business impact of confirmed threats.

CRITICAL	HIGH	MEDIUM	LOW
0	1	0	24

INFO	
0	107 IDENTIFIED ENDPOINTS

INFRASTRUCTURE & RECONNAISSANCE CONTEXT

🔒 SSL/TLS Configuration

Status: Insecure / Expired
Protocol: TLSv1.3
Issuer: Not Available
Expires In: 0 days

🛡️ Edge Defense / WAF

Detected WAF: Cloudflare
Confidence: 0.6%
Evasion Status: Active

🌐 Cloud / ASN Intelligence

Organization: Shopify, Inc.
Network Route: N/A
ASN: AS13335 Cloudflare, Inc.

📝 HTTP Security Headers

Strict-Transport-Security: Missing
Content-Security-Policy: Missing
X-Frame-Options: Missing

SECURITY POSTURE & CONFIGURATION CHECKS

Security Control	Status	Details
Transport Security (SSL/TLS)	❌ Insecure	Missing or expired SSL certificate. Data in transit is vulnerable.
Directory Listing Exposure	✅ Secure	No exposed internal directories detected.
HTTP Security Headers	✅ Hardened	Modern security headers (CSP, HSTS) are actively enforced.
Admin / Default Panel Protection	✅ Secure	No easily guessable admin panels or login portals found.

TECHNICAL FINDINGS & FORENSICS

A00:2021-General Security

LOW

Cookie not restricted to HTTPS

Observation: This cookie can be transmitted over unencrypted HTTP connections. Attackers on the same network (such as public Wi-Fi) may intercept it.

Technical Context: `Cookie: localization`

Remediation: Enable the Secure flag so the cookie is only sent over HTTPS connections.

LOW

Cookie accessible by browser scripts

Observation: This cookie can be accessed by JavaScript running on the website.

Technical Context: `Cookie: localization`

Remediation: Enable the HttpOnly flag to prevent JavaScript access.

LOW

Insecure SameSite=None Combination

Observation: The cookie is set to SameSite=None but is missing the Secure flag.

Technical Context: `Cookie: localization`

Remediation: Always set the Secure flag when using SameSite=None.

LOW

Cookie not restricted to HTTPS

Observation: This cookie can be transmitted over unencrypted HTTP connections. Attackers on the same network (such as public Wi-Fi) may intercept it.

Technical Context: `Cookie: _shopify_y`

Remediation: Enable the Secure flag so the cookie is only sent over HTTPS connections.

LOW

Cookie accessible by browser scripts

Observation: This cookie can be accessed by JavaScript running on the website.

Technical Context: `Cookie: _shopify_y`

Remediation: Enable the HttpOnly flag to prevent JavaScript access.

LOW

Cookie not restricted to HTTPS

Observation: This cookie can be transmitted over unencrypted HTTP connections. Attackers on the same network (such as public Wi-Fi) may intercept it.

Technical Context: `Cookie: _shopify_s`

Remediation: Enable the Secure flag so the cookie is only sent over HTTPS connections.

LOW

Cookie accessible by browser scripts

Observation: This cookie can be accessed by JavaScript running on the website.

Technical Context: `Cookie: _shopify_s`

Remediation: Enable the HttpOnly flag to prevent JavaScript access.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://pachchigarjewellers.com/cdn/shop/t/14/assets/libs.js?v=40073747709771798701769596259`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://pachchigarjewellers.com/cdn/shop/t/14/assets/global.js?v=97514697749446412101769852044`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://pachchigarjewellers.com/checkouts/internal/preloads.js?locale=en-IN`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://pachchigarjewellers.com/cdn/shopifycloud/shop-js/modules/v2/loader.init-shop-cart-sync.en.esm.js`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://pachchigarjewellers.com/cdn/shopifycloud/storefront/assets/storefront/load_feature-496de5fe.js`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://pachchigarjewellers.com/cdn/shopifycloud/portable-wallets/latest/portable-wallets.en.js`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

Unsafe HTML Assignment (innerHTML)

Observation: The script assigns content to innerHTML. If this content is not properly sanitized, it can execute scripts embedded in the HTML.

Technical Context: `Script: inline-script`

Remediation: Use element.textContent for plain text or use a trusted sanitization library (like DOMPurify) before using innerHTML.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://pachchigarjewellers.com/cdn/shopifycloud/perf-kit/shopify-perf-kit-3.3.0.min.js`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://pachchigarjewellers.com/cdn/shop/t/14/assets/custom-selectors.js?v=16782307165131029159177374970 3?v=2`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

Potential Malicious Script Signature

Observation: The script's content matches known patterns used by crypto-miners, credit card skimmers (Magecart), or obfuscation tools.

Technical Context: `Script: inline-script`

Remediation: Immediately investigate the source of this script and remove it if it is not legitimate.

LOW

External Script from Unknown Domain

Observation: This script is loaded from a third-party domain that is not on the trusted list.

Technical Context: `Script: https://cdn.xobuilder.app/pachchigarjewellers/wishlist/custom-code.js?v=1772018509086`

Remediation: Only load scripts from trusted providers and consider using Subresource Integrity (SRI) hashes.

LOW

Unsafe HTML Assignment (innerHTML)

Observation: The script assigns content to innerHTML. If this content is not properly sanitized, it can execute scripts embedded in the HTML.

Technical Context: `Script: inline-script`

Remediation: Use element.textContent for plain text or use a trusted sanitization library (like DOMPurify) before using innerHTML.

A10:2021-Server-Side Request Forgery

HIGH

SSRF Vulnerability

Observation: A Server-Side Request Forgery vulnerability was observed, potentially allowing servers to be coerced into making arbitrary internal/external requests.

Technical Context: `https://pachchigarjewellers.com/ (and 7 related endpoints)`

FORENSIC EVIDENCE & EXPLOIT PROOF

Affected URL: `https://pachchigarjewellers.com/ (and 7 related endpoints)`

```
Vulnerable Endpoints:\nhttps://pachchigarjewellers.com/?url=http://169.254.169.254/latest/meta-da
```

A05:2021-Security Misconfiguration

LOW

Hidden API / Status Endpoint

Observation: An internal or undocumented API endpoint was discovered.

Technical Context: `https://pachchigarjewellers.com/v1/metrics`

FORENSIC EVIDENCE & EXPLOIT PROOF

Affected URL: `https://pachchigarjewellers.com/v1/metrics`

```
https://pachchigarjewellers.com/v1/metrics
```

LOW

Hidden API / Status Endpoint

Observation: An internal or undocumented API endpoint was discovered.

Technical Context: `https://pachchigarjewellers.com/v1/logs`

FORENSIC EVIDENCE & EXPLOIT PROOF

Affected URL: `https://pachchigarjewellers.com/v1/logs`

```
https://pachchigarjewellers.com/v1/logs
```

LOW

Hidden API / Status Endpoint

Observation: An internal or undocumented API endpoint was discovered.

Technical Context: `https://pachchigarjewellers.com/v1/produce`

FORENSIC EVIDENCE & EXPLOIT PROOF

Affected URL: `https://pachchigarjewellers.com/v1/produce`

```
https://pachchigarjewellers.com/v1/produce
```

LOW Hidden API / Status Endpoint

Observation: An internal or undocumented API endpoint was discovered.

Technical Context: `https://pachchigarjewellers.com/api/2025-01/graphql`

FORENSIC EVIDENCE & EXPLOIT PROOF

Affected URL: `https://pachchigarjewellers.com/api/2025-01/graphql`

```
https://pachchigarjewellers.com/api/2025-01/graphql
```

LOW Missing Rate Limiting

Observation: An authentication or sensitive endpoint is missing rate limiting protections, making it vulnerable to brute-force attacks.

Technical Context: `https://pachchigarjewellers.com/`

FORENSIC EVIDENCE & EXPLOIT PROOF

Affected URL: `https://pachchigarjewellers.com/`

```
https://pachchigarjewellers.com/
```

CONFIDENTIAL DOCUMENT
This report contains sensitive security findings. Access should be restricted to authorized technical management.
© 2026 Vulnexa Security Systems. All rights reserved. Made by Akshat Jain.